

CareerBuddies Founder Ledger

Bug-Fix and Regression Report

Date 2026-10-09 · Baseline (approved checkpoint, unchanged on branch `claude/compassionate-bardeen-9zxrjv`): `8f0fa37` / report `55abe54` · Bug-fix branch: `bugfix/qa-2026-10-09` · Fix commit: `b0ae7e1` (this report is committed on top of it; final hash given in chat)

Readiness: PASS. All five defects from the QA audit (2 Medium, 3 Low) were reproduced on the baseline build, fixed, and verified fixed on the new build with the same test harness. Full regression is green and the approved UI is pixel-identical on 20 of 22 captured screens (the other 2 differ only in audit-log row content). The over-settlement observation was investigated and **deliberately not changed**; it needs your decision (section 7). The bug-fix branch is **not merged** and the real stack on `:8080` was not touched.

1. Scope and safeguards

- Work on a separate branch; the approved checkpoint (`8f0fa37` , report `55abe54`) is untouched.
- No change to UI design, layout, colours, logo, branding, typography, spacing or workflows; no change to financial rules, database schema or data.
- All reproductions and tests ran on isolated throw-away Docker stacks (`cbqa` , `cbfresh` , fresh volumes) and a throw-away test MongoDB, all removed afterwards. The real stack (`:8080`) was only read once at the end: its 4 transactions and founder balances are identical to before.

2. Defects, root cause, fix, before / after

ID	Sev.	Root cause	Fix	Before (baseline <code>8f0fa37</code> , executed)	After (<code>b0ae7e1</code> , executed)
PERS-07	Medium	<code>proxy_pass http://server:4000</code> is resolved by nginx only once at start-up. When the API container restarts with a new IP (e.g. <code>restart server mongo</code>) nginx keeps calling the old IP.	<code>docker/nginx.conf</code> : <code>resolver 127.0.0.11 valid=5s</code> and a variable <code>upstream (set \$api_upstream ...; proxy_pass \$api_upstream;)</code> so Docker DNS is re-queried every 5 s. Same URI passing, headers and limits.	FAIL: 502 for 70 s, 35 logged upstream failures, recovered only after restarting the client container.	PASS: QA test PERS-07 and PERS-06 pass; <code>tests/gateway-recovery.sh</code> prints "gateway healthy again without restarting it: yes". Full-suite proxy/API/DB flows unaffected.
UI-409	Medium	A 401 that survived the token-refresh attempt was only reported as an error to the page; auth state stayed "authenticated", so the protected-route guard never redirected.	<code>lib/api.ts</code> announces session loss (event) when refresh fails; <code>AuthContext</code> listens (only while signed in), clears state and the Login page shows "Your session has expired. Please sign in again." once.	FAIL: stuck on <code>/founders</code> showing "Authentication required [Retry]".	PASS: browser test UI-409 redirects to <code>/login</code> ; unit test "goes back to the login page, with a message, when the session expires..." passes; a never-signed-in visitor sees no message.
UI-102 / UI-109	Low	The mobile transaction card description had no <code>min-w-0 / break-words</code> , so an unbroken token (e.g. a URL or <code>=HYPERLINK("...")</code>) forced the flex row wider than the screen.	<code>TransactionsPage.tsx</code> : description gets <code>min-w-0 break-words</code> (two utility classes, no visual change for normal text).	FAIL: horizontal overflow 21 px at 320 px in the audit; reproduced with the same fixture at 49 px (390) / 119 px (320).	PASS at 1366 / 820 / 390 / 320 for both Transactions and the Add Transaction route, same fixture.
UI-110	Low	Every visit to <code>/login</code> asked the server <code>GET /auth/me</code> and <code>POST /auth/refresh</code> ; for a signed-out visitor both return 401, which browsers print as console errors.	<code>AuthContext</code> : on <code>/login</code> , browsers with no "signed in before" hint (a <code>localStorage</code> flag, no token or personal data) skip the probe. All other pages still ask the server, so existing signed-in users are not logged out; genuine errors are still logged (only the expected probe is skipped).	FAIL: 2 console errors (401 <code>/auth/me</code> , 401 <code>/auth/refresh</code>).	PASS: 0 console errors; unit tests prove no probe on <code>/login</code> without hint, a probe on protected pages, hint set on login/restore and cleared on loss.
OBS-01	Low	Five route modules created their express-rate-limit instance lazily inside a request handler, which the library reports as <code>ERR_ERL_CREATED_IN_REQUEST_HANDLER</code> .	<code>middleware/rateLimit.ts</code> : <code>deferredLimiter()</code> keeps one instance per module (same counters, env read at creation)	FAIL: 3 validation errors in a short baseline run (33 in the audit).	PASS: 0 in the full 133-check API run; new server test fails on the baseline and passes

		and <code>initRateLimiters()</code> (called from <code>createApp</code>) creates them at start-up.	now; SEC-09 login throttling still returns 429; limiter unit test proves the limit (200,200,429,429) and a single instance.
--	--	---	---

3. Changed files (git diff --stat 55abe54..b0ae7e1)

CB-Founder-Ledger/client/src/App.test.tsx	66 ++++++
CB-Founder-Ledger/client/src/auth/AuthContext.tsx	44 ++++++
.../src/features/transactions/TransactionsPage.tsx	2 +-
CB-Founder-Ledger/client/src/lib/api.ts	16 +++++
CB-Founder-Ledger/client/src/pages/LoginPage.tsx	3 +-
CB-Founder-Ledger/client/src/test/utils.tsx	2 +
CB-Founder-Ledger/docker/nginx.conf	8 +-+
CB-Founder-Ledger/docs/PROPOSAL-OVER-SETTLEMENT.md	32 ++++++
CB-Founder-Ledger/server/src/app.ts	3 +
.../server/src/middleware/rateLimit.ts	20 ++++++
.../server/src/modules/founders/founders.routes.ts	5 +-
.../server/src/modules/receipts/receipts.routes.ts	5 +-
.../src/modules/recurring/recurring.routes.ts	5 +-
.../server/src/modules/settings/settings.routes.ts	5 +-
.../modules/transactions/transactions.routes.ts	7 +-+
.../server/tests/rateLimit.init.test.ts	25 ++++++
CB-Founder-Ledger/server/tests/rateLimit.test.ts	20 ++++++
CB-Founder-Ledger/tests/gateway-recovery.sh	13 +++++
18 files changed, 254 insertions(+), 27 deletions(-)	

4. Regression test results (all executed)

Check	Result
Typecheck (server + client)	0 errors
Production builds (server tsc, client Vite)	clean
Server tests (real MongoDB 7)	405 / 405 in 27 files (was 403; +2 new rate-limiter tests, one verified to fail on the baseline)
Client tests	107 / 107 in 7 files (was 101; +6 new session/login-probe tests)
QA API / security / financial / persistence harness (re-run in full)	133 / 133 rows executed, 0 failed, including Option C reimbursements, settlements, approval rules enforced by the backend, authorization matrix, audit log, CSV, restart persistence, DB-outage recovery, API+DB simultaneous restart (PERS-07) and login rate-limit (SEC-09). Two of the 133 are the earlier "not a feature / design note" rows with no assertion.
QA browser harness (re-run in full, Chromium, 4 viewports per page)	51 / 51 (50 in the full run; UI-305 failed once only because a leftover test category from an earlier run polluted its check — harness fixed to use a unique name and re-run: pass)
Existing browser regression suite (163 checks: login, founder order, photos, settings propagation, modal create/approve, Option C, settlements, recurring, reports, audit, responsive) on a freshly rebuilt stack	163 / 163
Gateway recovery script	pass

Harness adjustments made during this phase (not product changes): UI harness uses unique names for fixtures; an overflow fixture with an unbroken token was added so UI-102/109 can be reproduced.

5. Approved UI unchanged (visual comparison)

The same 11 screens at desktop (1366×850) and mobile (390×844) were captured on a baseline build and on the fixed build from freshly seeded databases and compared pixel by pixel: **20 of 22 identical** (login, dashboard, founders, transactions, settlements, approvals, recurring, reports, settings, Add Transaction modal, desktop and mobile). The 2 differences (audit log) are the timestamps and ids of the event rows; layout is identical.



Welcome Back

Sign in to access CareerBuddies Founder Ledger.

Email

Password

Sign in



Welcome Back

Sign in to access CareerBuddies Founder Ledger.

Email

Password

Sign in

Login (fixed)



Transactions



Every recorded transaction. Voided entries stay visible for the audit trail.

 Add transaction

All

Pending

Approved

Rejected

 Search description, notes or TXN num

All types



All statuses



All categories



Any founder



Receipt: any



mm/dd/yyyy 

–

mm/dd/yyyy 

No transactions yet

Add the first transaction to start the ledger.

Add transaction

Transactions mobile (baseline)

☰

Transactions

↗

Every recorded transaction. Voided entries stay visible for the audit trail.

⊕ Add transaction

All

Pending

Approved

Rejected

🔍 Search description, notes or TXN num

All types ▾

All statuses ▾

All categories ▾

Any founder ▾

Receipt: any ▾

mm/dd/yyyy 📅 – mm/dd/yyyy 📅

No transactions yet

Add the first transaction to start the ledger.

Add transaction

Transactions mobile (fixed)

6. Behaviour changes users may notice

- If a session ends while the app is open, the user is returned to the Login page with a one-line notice (previously a stuck "Authentication required" page).
- Existing signed-in users stay signed in after the update (protected pages still ask the server); the "signed in before" flag is created on their next successful load or sign-in.
- Gateway: nothing visible; it now follows the API after restarts.

7. Phase 3 — over-settlement through the generic Add Transaction form (no change made)

Investigation: this is the documented, approved Phase 3 behaviour **IA-10** ("over-settlement is allowed and explicit"). The engine flags it (`overSettledMinor`, `OVER_SETTLED` warning, reconciliation `REVIEW`, dashboard "1 record needs attention"), net positions still sum to zero, voiding restores balances, and existing tests cover it. The guided Record payment flow already blocks it. Because blocking would change accounting policy, **nothing was changed**. Options A-D (keep, warn in form, block at approval, block at creation) and a recommendation (B now; C only with an admin override and audit reason) are in `docs/PROPOSAL-OVER-SETTLEMENT.md`. **Awaiting your decision.**

8. Unresolved / not covered

- Over-settlement policy decision (above).
- Not re-tested because unchanged and out of environment reach: your Windows PC, real TLS/Secure cookies, non-Chromium browsers, screen-reader audit, load, backup/restore, PDF/JPG/WebP upload variants, token-expiry timing (see the QA report, section 8).
- The restart fix was verified on Docker Compose with Docker DNS (127.0.0.11). On a different container platform the `resolver` address would need adjusting.
- The real stack on :8080 still runs the old build; to adopt the fixes, merge the branch and rebuild (`docker compose --env-file .env -f docker/docker-compose.yml up --build -d`, no volume deletion).
- Previously audit observations not addressed by design (self-approval default, any founder can approve, no 2FA/lockout, audit immutability at app level) remain as documented.

9. Final readiness assessment

PASS. Every targeted defect is fixed with before/after execution evidence, no regression was found in 405 server, 107 client, 133 API, 51 browser-QA and 163 browser-regression checks, the approved UI is unchanged, and no financial rule, schema or real data was altered. Pending only your approval to merge, and your decision on the over-settlement proposal.